ShadowMem — Hackathon Round 1 Defense Brief

Verifiable Pitch Script, Live Demo Assets, Differentiation & Judge Q&A;

1. THE 30-SECOND PITCH (Spoken Out Loud)

*"Traditional antivirus scans files sitting on your hard drive, but modern attacks live entirely inside memory without saving a single file to disk. **ShadowMem** is a lightweight, agentless volatile memory inspection tool for Windows. It uses standard user-mode Win32 calls to walk the private memory spaces of running processes, detects malicious executable allocations and unbacked threads, filters out harmless browser runtimes, and scores threats with a trained machine-learning model. If an attack is detected, an analyst can freeze the process in place with one click."*

2. THE 90-SECOND VERSION

a. Problem: Attackers increasingly use **fileless malware and process injection** (reflective DLL injection, shellcode). Because execution lives in RAM and never touches disk, file-based antiviruses miss them entirely.

b. Solution: ShadowMem is an agentless, user-mode cyber defense tool that inspects the volatile RAM of active Windows processes and classifies in-memory threats using ML.

c. How It Works (Pipeline): Enumerates PIDs via psutil → opens handles via OpenProcess → traverses allocated pages with VirtualQueryEx → flags private executable regions (MEM_COMMIT + MEM_PRIVATE) and RW→RX protection flips → inspects thread entry points via NtQueryInformationThread → allowlists JIT runtimes (Chrome, Brave, Node.js) → scores via HistGradientBoostingClassifier.

d. Live Demo Ready Now: Live memory audit (~130 PIDs in 4-6s), process containment (freeze/resume threads via SuspendThread / ResumeThread), 2D polar radar scope, simulated WebSocket alert trigger (/api/v1/simulate/alert), CSV/PDF export.

e. Innovation: Non-destructive, zero-driver user-mode triage. Eliminates Blue Screen (BSOD) risks while automating JIT false-positive suppression.

f. Tech Stack: FastAPI (Python 3.14, ctypes Win32), Next.js 14 (React, TypeScript, Tailwind, Recharts), scikit-learn (HistGradientBoosting, 7 features), WebSockets.

g. Roadmap (In Progress): Containerized Docker sandbox for untrusted binaries and supply-chain dependency scanner are currently architectural scaffolding.

3. HOW SHADOWMEM IS DIFFERENT

Capability	Traditional Antivirus	Enterprise EDR (CrowdStrike)	Memory Forensics (Volatility)	ShadowMem
Primary Scope	Static files on disk	System calls & event streams	Offline post-mortem RAM dump files	**Live volatile process RAM in user space**
Driver Footprint	Kernel driver (Ring-0)	Heavy kernel sensor (Ring-0)	None (offline dump file)	**Zero drivers (100% user-mode Win32)**
Crash Risk (BSOD)	Medium	High (kernel updates risk outages)	None	**Zero (cannot crash OS kernel)**
Triage Speed	Minutes (disk bound)	Continuous telemetry stream	Hours (analyzing multi-GB dumps)	**Seconds (~4–6s full memory sweep)**
Containment	Quarantines file on disk	Network isolation / process kill	Read-only analysis (no response)	**User-mode thread suspend (freezes RAM)**

4. RELEVANCE TO RECENT ATTACKS

- **Reflective DLL Injection (Cobalt Strike, Ransomware)**: Payloads inject directly into memory pages marked RWX without touching disk. ShadowMem identifies these unbacked allocations immediately.
- **Living-off-the-Land (LOLBins)**: Attackers hollow or inject into signed Windows processes (svchost.exe, explorer.exe). Disk scanners see a valid signature; ShadowMem spots unbacked execution threads.
- **Memory Protection Flips (VirtualProtect Abuse)**: Attackers bypass DEP by allocating memory as Read-Write and flipping it to Executable right before execution. ShadowMem explicitly tracks VAD protection anomalies.

5. HONEST LIMITATIONS & READY ANSWERS

Weak Spot / Question	Your Confident, Honest Answer
User-Mode Only (No Kernel Hooking)	*"ShadowMem runs strictly in user mode to guarantee non-crashing operational safety and rapid deployment. It leaves kernel pool analysis to specialized EDR sensors."*
Protected Processes Light (PPL Blindspot)	*"Processes like Windows Defender (MsMpEng.exe) enforce kernel protections that return Access Denied to user-mode handles. ShadowMem safely logs and skips them."*
Sandbox & Supply Chain Incomplete	*"Those two modules are currently architectural scaffolding on our roadmap. Our working core today is volatile memory forensics and live process containment."*
Unauthenticated Local Endpoints	*"The current REST/WebSocket APIs run unauthenticated for fast hackathon demo evaluation. In enterprise deployment, they would be secured behind mTLS and OAuth2."*

6. TEN LIKELY JUDGE QUESTIONS (Under 30 Words Each)

1. **How is this different from antivirus?** Antivirus scans files on disk. ShadowMem inspects live virtual address spaces in RAM to catch fileless code that never writes to storage.
2. **What is your false positive rate?** Our training evaluation achieved under 0.2% false positives by explicitly using a JIT allowlist that caps browser JavaScript engines below threat thresholds.
3. **Why does process count change between scans?** Windows continuously starts and stops background tasks (telemetry, update workers, browser tabs). The count reflects actual processes opened successfully during that specific scan.
4. **Does ShadowMem require Admin rights?** Yes. As a standard user it only scans your own user-session (~40 PIDs). Admin rights (SeDebugPrivilege) allow it to inspect all system processes (~130+).
5. **What happens when a threat is found?** It flags the PID, assigns a MITRE classification, and allows one-click thread suspension (SuspendThread) to freeze execution without destroying memory evidence.
6. **Is this production-ready?** It is a functional working prototype. The memory traversal, ML classification, and thread containment work live today, while authentication and container sandboxing are roadmap items.
7. **Can your containment tool crash Windows?** No. Our containment service enforces safety checks refusing to isolate critical operating system processes like csrss.exe, smss.exe, or lsass.exe.
8. **What machine learning model is loaded?** A scikit-learn HistGradientBoostingClassifier with RobustScaler, evaluating 7 volatile memory features across 9 classes (5 benign types, 4 injection techniques).
9. **Why not build a kernel driver?** Kernel drivers require Microsoft signing, introduce kernel attack surfaces, and risk BSOD crashes. User-mode VirtualQueryEx provides fast, reliable, non-destructive triage.
10. **What are the 7 features evaluated?** RWX page count, unbacked executable pages, total RWX bytes, active thread count, threads starting in unbacked memory, JIT runtime flag, and protection-flip anomalies.